CVE-2026-3888: Important Snap Flaw Enables Local Privilege Escalation to Root

Saeed Abbasi, Senior Manager, Threat Research Unit, Qualys

March 18, 2026 - 7 min read

10 Share

Table of Contents

- What is the attack surface for CVE-2026-3888?
- Exploitation Mechanism:
- Affected Versions & Remediation
- Technical Details
- Secondary Finding: Vulnerability in Ubuntu 25.10 uutils Coreutils
- Qualys QID Coverage for Detecting theCVE-2026-3888:
- Discover Vulnerable Assets with Qualys CyberSecurity Asset Management
- Enhancing Your Security Posture with Qualys VMDR to Detect and Remediate the CVE-2026-3888 Vulnerability
- Automatically Patch CVE-2026-3888 with Qualys Patch Management

The Qualys Threat Research Unit has identified a Local Privilege Escalation (LPE) vulnerability affecting default installations of Ubuntu Desktop version 24.04 and later. This flaw (CVE-2026-3888) allows an unprivileged local attacker to escalate privileges to full root access through the interaction of two standard system components: snap-confine and systemd-tmpfiles.

While the exploit requires a specific time-based window (10–30 days), the resulting

impact is a complete compromise of the host system.

The vulnerability stems from an unintended interaction between two privileged utilities:

- **snap-confine:** Manages execution environments for snap applications (set-user-ID-root or set capabilities).
- **systemd-tmpfiles:** Automatically cleans up temporary files and directories older than a defined threshold.

Additionally, during the review process for Ubuntu 25.10, a separate vulnerability in the uutils coreutils package was identified and mitigated prior to release through proactive collaboration with the Ubuntu Security Team; more details on that finding follow below.

What is the attack surface for CVE-2026-3888?

snapd is the background service that manages the entire Snap ecosystem on Ubuntu. It handles discovery, installation, updates, and removal of snap packages — self-contained application bundles that ship with their own dependencies rather than relying on shared system libraries. Canonical designed the format to solve dependency conflicts and give publishers a single packaging target across Ubuntu versions. snapd also enforces the permission model that governs what each snap can access on the host system, making it both a package manager and a security policy engine.

Understanding snapd matters here because the two components below, snap-confine and systemd-tmpfiles, operate within or alongside this framework. snap-confine is the enforcement arm that actually builds the sandbox snapd defines, and systemd-tmpfiles handles the volatile filesystem plumbing that both snaps and system services depend on.

snap-confine: snap-confine is the setuid root binary that builds the sandbox before a snap app runs. It handles mount namespace isolation, cgroup enforcement, AppArmor policy loading, and seccomp filtering—the full confinement stack that keeps snaps

from leaving their boundaries. Because it runs with elevated privileges to set up kernel-level isolation for regular users, it sits at a critical trust boundary. A bug like CVE-2026-3888 in this component could lead to privilege escalation, which makes consistent snapd patching a practical priority.

systemd-tmpfiles: systemd-tmpfiles manages the lifecycle of volatile directories like /tmp, /run, and /var/tmp — creating them with the right ownership at boot and cleaning out stale files on a timer. Configuration lives in drop-in files under /etc/tmpfiles.d/, /run/tmpfiles.d/, and /usr/lib/tmpfiles.d/. Poorly configured tmpfiles rules can create local escalation paths and open the door to symlink races and local escalation.

Exploitation Mechanism:

CVE-2026-3888 is rated High severity with a CVSS v3.1 score of 7.8 out of 10. The vector string (AV:L/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H) indicates a local attack vector with high complexity, requiring low privileges and no user interaction. The scope is changed, meaning a successful exploit can impact resources beyond the vulnerable component, with high impact across confidentiality, integrity, and availability.

While the CVSS score reflects a High severity, the Attack Complexity is High due to an inherent time-delay mechanism in the exploit chain. In default configurations, systemd-tmpfiles is scheduled to remove stale data in /tmp. An attacker can exploit this by manipulating the timing of these cleanup cycles. Specifically, the attack vector involves:

1. The attacker must wait for the system's cleanup daemon (30 days in Ubuntu 24.04; 10 days in later versions) to delete a critical directory (/tmp/.snap) required by snap-confine.
2. Once deleted, the attacker recreates the directory with malicious payloads.
3. During the next sandbox initialization, snap-confine bind-mounts these files as root, allowing the execution of arbitrary code within the privileged context.

Affected Versions & Remediation

The following snapd package versions are vulnerable. Organizations should upgrade immediately to the listed patched releases:

- Ubuntu 24.04 LTS: snapd versions prior to 2.73+ubuntu24.04.2
- Ubuntu 25.10 LTS: snapd versions prior to 2.73+ubuntu25.10.1
- Ubuntu 26.04 LTS (Dev): snapd versions prior to 2.74.1+ubuntu26.04.1
- Upstream snapd: versions prior to 2.75

Legacy Systems (16.04–22.04 LTS): While not vulnerable in default configurations, it is recommended to apply the patch to these versions as well. This precaution mitigates risks associated with non-default configurations that may mimic the behavior of newer releases.

Organizations running Ubuntu Desktop >= 24.04 should apply the patches immediately.

Technical Details

You can find the technical details of these vulnerabilities at:

https://cdn2.qualys.com/advisory/2026/03/17/snap-confine-systemd-tmpfiles.txt

Secondary Finding: Vulnerability in Ubuntu 25.10 uutils Coreutils

In a proactive security effort prior to the release of Ubuntu Desktop 25.10, the Qualys Threat Research Unit assisted the Ubuntu Security Team in reviewing the uutils coreutils package (a Rust rewrite of standard GNU utilities).

A race condition in the rm utility allowed an unprivileged local attacker to replace directory entries with symlinks during root-owned cron executions (specifically /etc/cron.daily/apport). Successful exploitation could lead to arbitrary file deletion as root or further privilege escalation by targeting snap sandbox directories.

The vulnerability was reported and mitigated prior to the public release of Ubuntu 25.10. The default rm command in Ubuntu 25.10 was reverted to GNU coreutils to mitigate this risk immediately. Upstream fixes have since been applied to the uutils repository.

Qualys QID Coverage for Detecting the CVE-2026-3888:

Qualys is releasing the QIDs in the table below as they become available.

QID	Title	VulnSigs Version
386810	Ubuntu Snapd Local Privilege Escalation (LPE) Vulnerability	VULNSIGS-2.6.561-4

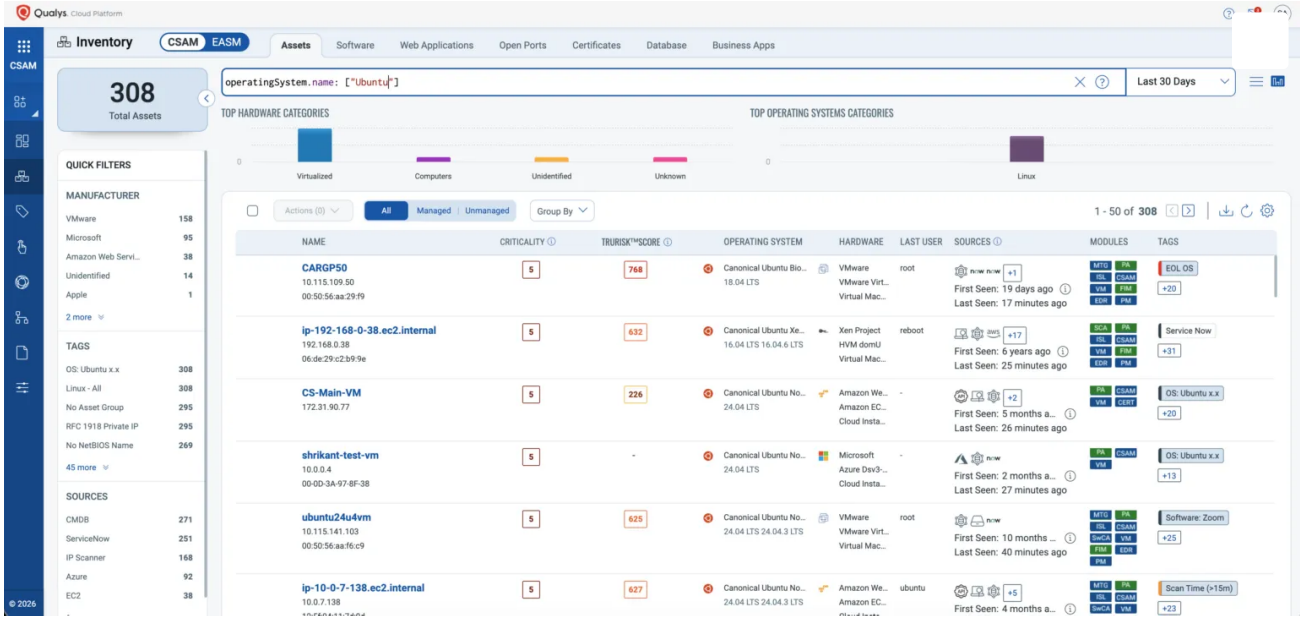
Please check the Qualys Vulnerability Knowledgebase for the full list of coverage for this vulnerability.

Discover Vulnerable Assets with Qualys CyberSecurity Asset Management

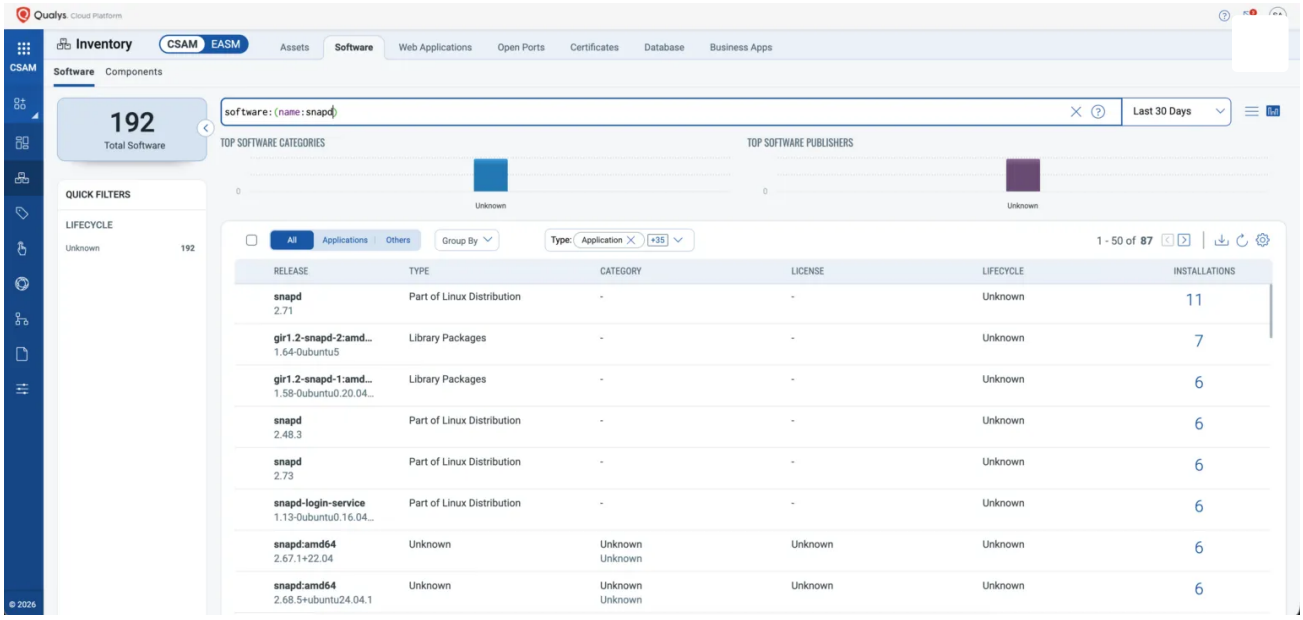
The initial and crucial step in managing this critical vulnerability and mitigating associated risks is identifying all assets susceptible to this issue. Use CyberSecurity Asset Management 3.0 with External Attack Surface Management to identify your organization's internet-facing instances and container/Kubernetes nodes that have vulnerable versions of the snap vulnerability.

In the following example, we aim to identify all assets running Ubuntu:

```
operatingSystem. name: ["Ubuntu"]
```




```
software:(name:"apparmor")
```



CyberSecurity Asset Management maintains a catalog of hardware and software lifecycle data built and curated by a dedicated research team, covering over 5,500 software publishers and 300,000 software releases, with automated daily updates to all CyberSecurity Asset Management customers.

FREE TRIAL

Start a free trial of Qualys CyberSecurity Asset Management

Try Today

(CSAM) Today.

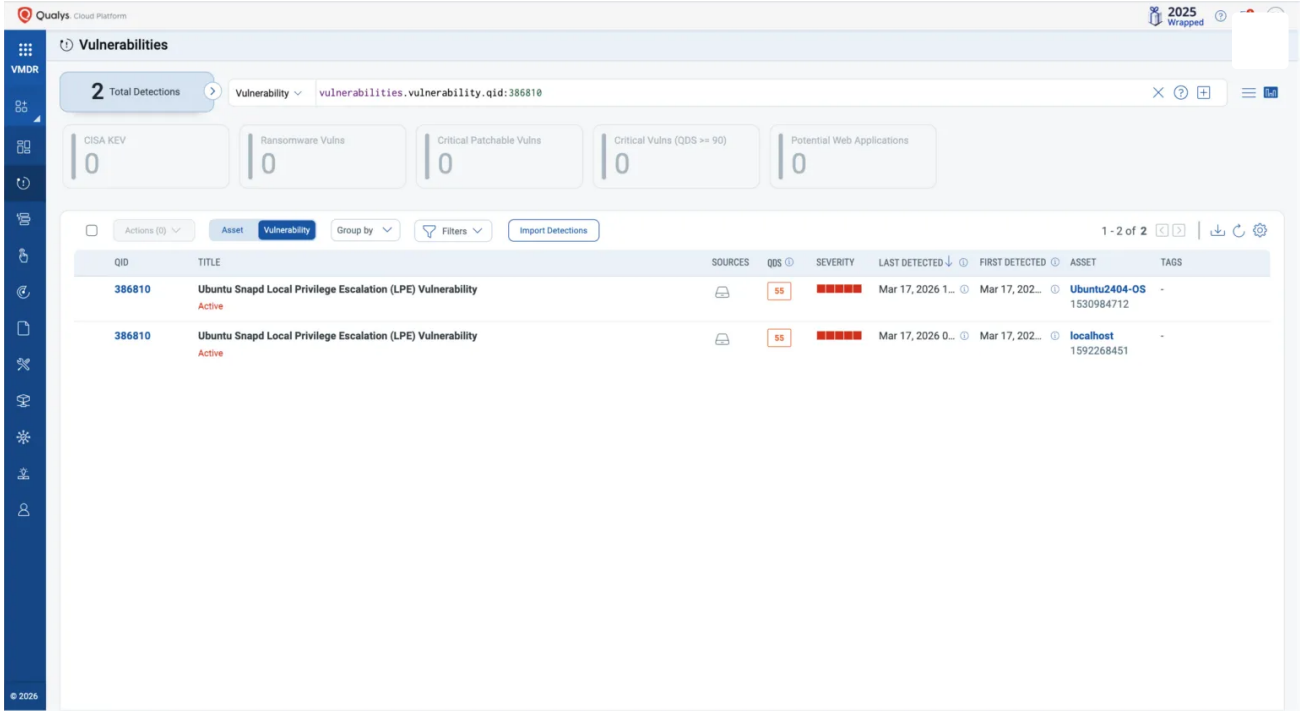
Enhancing Your Security Posture with Qualys VMDR to Detect and Remediate the CVE-2026-3888 Vulnerability

Qualys VMDR provides comprehensive coverage and visibility into vulnerabilities, empowering organizations to rapidly respond, prioritize, and mitigate associated risks. Additionally, Qualys customers can leverage Qualys Patch Management to effectively remediate these vulnerabilities.

Leverage the power of Qualys VMDR alongside TruRisk™ and the Qualys Query Language (QQL) to efficiently identify and prioritize vulnerable assets, including container and Kubernetes nodes, effectively addressing the vulnerabilities highlighted above.

Use this QQL statement:

```
vulnerabilities.vulnerability.qid: 386810
```



VMDR

FREE TRIAL

Start a free trial of Qualys VMDR Today.

Try Today

Automatically Patch CVE-2026-3888 with Qualys Patch Management

Patches for this vulnerability are available. Qualys Patch Management can automatically deploy those patches to vulnerable assets when they become available.

Customers can use the “patch now” button found to the right of the vulnerability to add this vulnerability to a patch job. Once patches are released, Qualys will find the relevant patches for this vulnerability and automatically add those patches to a patch job. This will allow customers to deploy those patches to vulnerable devices, all from the Qualys platform.

FREE TRIAL

Start a free trial of Qualys TruRisk Eliminate Today.

Try Today

Explore the power of the Qualys Enterprise TruRisk Platform or Enterprise TruRisk Management and get a unified view of risk today.

Written by
Saeed Abbasi, Senior Manager, Threat Research Unit, Qualys
Write to Saeed at sabbasi@qualys.com

Like Share

Related content
Qualys TRU, snap, Ubuntu

SHOW COMMENTS (1)

Join the discussion today!

Learn more about Qualys and industry best practices.

Share what you know and build a reputation.

Secure your systems and improve security for everyone.

Start a discussion

© 2026 Qualys, Inc. All rights reserved. Privacy Policy . Accessibility